AI-Driven Hybrid Detection Framework for PowerShell-Based Fileless Malware in Healthcare IoMT Systems

R26-CS-006

Project Proposal Report

Fernado M.S.V – IT22080530

B.Sc. (Hons) Degree in Information Technology Specialized in Cybersecurity

Department of Computer systems and Engineering

Sri Lanka Institute of Information Technology Sri Lanka

March 2024

Powershell base file less malware detection

R26-CS-006

Project Proposal Report

Fernado M.S.V – IT22080530

B.Sc. (Hons) Degree in Information Technology Specialized in Cybersecurity

Department of Computer systems and Engineering

Sri Lanka Institute of Information Technology Sri Lanka

March 2024

DECLARATION

I declare that this is my own work, and this proposal does not knowingly incorporate any material previously submitted for a degree or diploma at any other university or higher education institution, nor does it contain any material that has been previously published or written by another person apart from where proper acknowledgment is given in the text.

Name	Student ID	Signature
Shakya W.A. R	IT22210142	
Fernando M.S. V	IT22080530	
Pagodaarachchi R. T.	IT22135070	
Chathuranga L.A. S	IT22108272	

The above candidate is conducting research for their undergraduate Dissertation under my supervision.

Name	Date	Signature
Mr. Kanishka Yapa.	13/03/2026	
Mr. Dinith Primal.	13/03/2026	

ABSTRACT

Healthcare organizations increasingly rely on interconnected digital systems and Internet of Medical Things (IoMT) devices to improve patient monitoring, diagnostics, and healthcare delivery. However, this growing connectivity introduces significant cybersecurity risks. One of the most dangerous emerging cyber threats targeting healthcare systems is fileless malware. Unlike traditional malware that relies on malicious files stored on disk, fileless malware operates entirely in system memory using legitimate tools such as PowerShell, Windows Management Instrumentation (WMI), and Windows APIs. These attacks leave minimal traces on the system and can easily bypass traditional signature-based antivirus solutions.

This research proposes an Artificial Intelligence (AI) driven framework for detecting PowerShell-based fileless malware in healthcare environments. The system analyzes behavioral patterns extracted from endpoint telemetry logs collected using Sysmon monitoring tools. Features such as command-line entropy, suspicious PowerShell commands, API invocation frequency, and event sequence patterns are extracted and used as inputs for machine learning models.

The proposed framework integrates both traditional machine learning and deep learning techniques. XGBoost classifiers will be used to analyze static behavioral features, while Long Short-Term Memory (LSTM) neural networks will analyze sequential event logs to identify temporal anomalies. An ensemble detection approach will combine both models to improve detection accuracy.

Explainable Artificial Intelligence (XAI) techniques such as SHAP and LIME will be used to provide interpretable explanations for predictions. Additionally, federated learning will allow hospitals to collaboratively train detection models without sharing sensitive patient data.

The final outcome will be a lightweight, explainable, and privacy-preserving malware detection system capable of identifying fileless attacks in real-time healthcare environments.

ACKNOWLEDGEMENT

I would like to express my sincere gratitude to my supervisor and co-supervisor, Mr. Kanishka Yapa and Mr. Dinith Primal, for their valuable guidance, constructive feedback, and continuous encouragement during the preparation of this proposal. Their comments helped refine the research scope, technical direction, and implementation strategy of this component. I also acknowledge the support of my lecturers and teammates for the discussions and ideas that contributed to shaping the broader research framework. Finally, I thank the Sri Lanka Institute of Information Technology for providing the academic environment required to pursue this research on cybersecurity for healthcare systems.

Table Contents

ACKNOWLEDGEMENT 5
LIST OF TABLES 8
LIST OF FIGURES 9
LIST OF ABBREVIATIONS 10
1. INTRODUCTION 11
1.1 Background And Context 11
1.2 Literature Review 13
1.3 Research Gap 14
2. OBJECTIVES 16
2.1 Main Objective: 16
2.2 Specific Objectives: 16
3. METHODOLOGY 17
3.1 Research Approach 17
3.2 Technical Methods and Algorithms 17
3.3 Tools and Platforms 19
3.4 Data Collection and Ethical Considerations 20
3.5 Validation Strategy and Performance Metrics 20
4. HIGH-LEVEL SYSTEM ARCHITECTURE 21
4.1 Overview of the Proposed Solution and Its Components 21
4.2 System Diagram of Components 22
4.3 Individual Component and Its Parts 22
4.4 Component Interactions 23
4.5 Data Flow Explanation 23
4.6 Scalability and Security Considerations 24
5.USER REQUIREMENTS 25
5.1 Stakeholder Identification 25
Stakeholder 25
Several stakeholders are involved in the implementation and use of the proposed fileless malware detection system. 25
5.2 Functional Requirements 26
FR8: The system shall store detected anomaly results and generated alerts in a secure log repository for further investigation and analysis by security analysts. 26

5.3 Non-Functional Requirements 27
6. COMMERCIALIZATION PLAN 28
6.1 Target Market and Customer Persona 28
6.2 Value Proposition 28
6.3 Revenue Model 29
6.4 Pricing Strategy 30
6.5 Competitive Advantage 30
6.6 Intellectual Property Considerations 31
8. WORK BREAKDOWN STRUCTURE 33
9.GANTT CHART 34
..... 34
10.REFERENCES 36

LIST OF TABLES

Table 1: Comparison of Previous Research 15
Table 2 Tools and platforms with justification 19
Table 3Pricing Strategy for the Proposed Cybersecurity System 30

LIST OF FIGURES

Figure 1 Figure 1: Hybrid AI-driven multi-layer security framework workflow diagram. 12
Figure 2 – High-Level System Architecture of the Proposed PowerShell-Based Fileless Malware Detection Component 22
Figure 3 Work breakdown structure within the timeline 33
Figure 4 Overall research project gantt chart 34
Figure 5 Component 2 gantt chart. 35

LIST OF ABBREVIATIONS

IoMT – Internet of Medical Things

ML – Machine Learning

DL – Deep Learning

XAI – Explainable Artificial Intelligence

WMI – Windows Management Instrumentation

SOC – Security Operations Center

API – Application Programming Interface

SIEM – Security Information and Event Management

1. INTRODUCTION

1.1 Background And Context

The rapid advancement of digital technologies has significantly transformed modern healthcare systems through the integration of the Internet of Medical Things (IoMT)**.** IoMT refers to a network of interconnected medical devices, healthcare applications, and information systems that collect and exchange patient data through the internet. Devices such as smart infusion pumps, wearable health monitors, medical imaging systems, and patient monitoring devices are increasingly connected to hospital networks to improve healthcare efficiency, remote monitoring, and clinical decision-making. While IoMT technologies provide numerous benefits for patient care and healthcare management, they also introduce significant cybersecurity risks due to the increased connectivity and complexity of healthcare infrastructures [1].

Healthcare organizations have become one of the most attractive targets for cybercriminals because they store highly sensitive patient information and operate critical infrastructures where service disruptions can have life-threatening consequences. According to global cybersecurity reports, the healthcare sector experiences some of the highest financial losses from cyberattacks, with the average cost of a healthcare data breach exceeding USD 10 million globally in recent years [2]. Furthermore, ransomware attacks and advanced persistent threats targeting hospitals have increased significantly, highlighting the urgent need for stronger cybersecurity mechanisms within healthcare environments.

Among the various cyber threats targeting healthcare systems, fileless malware attacks have emerged as one of the most sophisticated and difficult-to-detect attack techniques. Unlike traditional malware that relies on malicious executable files stored on disk, fileless malware operates entirely in system memory using legitimate system tools such as PowerShell, Windows Management Instrumentation (WMI), and application programming interfaces (APIs)**.** Attackers exploit these trusted system utilities to execute malicious scripts, steal credentials, establish persistence mechanisms, and move laterally across hospital networks without leaving obvious traces on the system [3]. Because fileless malware does not rely on traditional files, many signature-based antivirus systems and conventional malware detection techniques fail to detect these attacks effectively**.**

Existing cybersecurity solutions for detecting malware in healthcare networks mainly focus on signature-based detection or network-level anomaly detection techniques**.** However, these approaches have several limitations when dealing with fileless malware attacks. Signature-based detection systems are ineffective against new or obfuscated malware variants, while network-based detection methods often fail to capture endpoint-level behaviors such as suspicious PowerShell commands, abnormal WMI activities, or malicious API call sequences**.** Additionally, many machine learning-based detection frameworks operate as black-box models, which provide limited transparency and make it difficult for security analysts to interpret and trust detection results in critical healthcare environments [4].

To address these challenges, this research proposes an AI-driven behavioral detection mechanism for identifying PowerShell-based fileless malware attacks at the endpoint level**.** The proposed solution focuses on analyzing system telemetry collected from Windows endpoints using Sysmon event logs**,** which capture detailed behavioral information including process creation events, command-line activities, module loading patterns, and WMI interactions. By extracting

behavioral features from these logs, machine learning models can learn patterns that distinguish legitimate administrative activities from malicious fileless attack behaviors.

The proposed component utilizes a hybrid machine learning approach combining XGBoost and Long Short-Term Memory (LSTM) neural networks to detect anomalies associated with PowerShell-based attacks. XGBoost is used for structured feature classification, while LSTM models capture sequential behavioral patterns in system events. Additionally, deobfuscation techniques are incorporated to analyze encoded or obfuscated PowerShell commands commonly used by attackers. To improve transparency and trustworthiness of the detection system, Explainable Artificial Intelligence (XAI) methods such as SHAP and LIME are integrated to provide interpretable explanations for model decisions.

Another key feature of the proposed solution is the implementation of federated learning, which enables distributed model training across multiple healthcare institutions or IoMT endpoints without sharing raw security logs. This approach helps preserve sensitive patient data and ensures compliance with healthcare privacy regulations while still allowing collaborative threat intelligence sharing. Furthermore, the system is designed for low-latency edge deployment, enabling real-time detection directly on IoMT gateways or endpoint devices with limited computational resources.

This research contributes to a broader cybersecurity framework designed to protect IoMT environments from advanced threats. Within this framework, the proposed component focuses specifically on endpoint-level detection of PowerShell-based fileless malware, generating actionable alerts that can be integrated with other system components responsible for predictive threat analysis and cross-layer attack correlation.

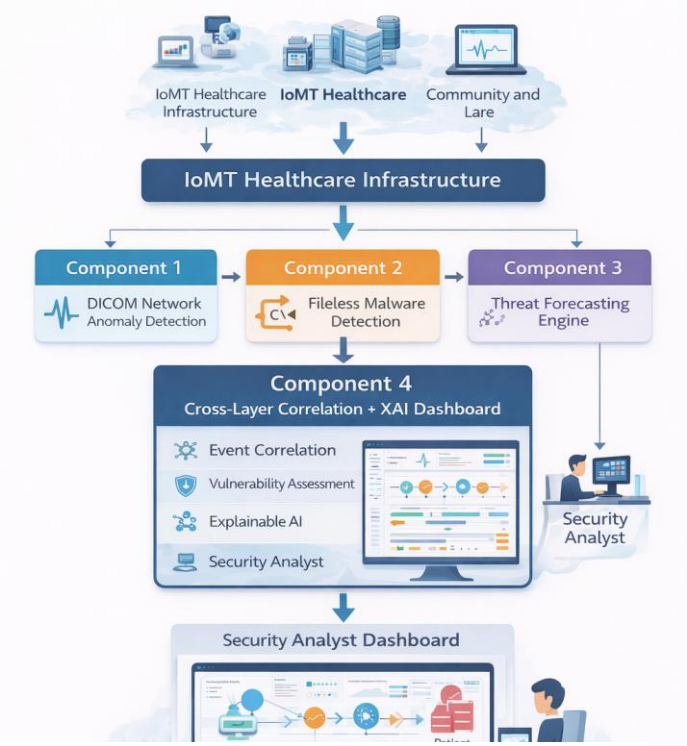


Figure 1 Figure 1: Hybrid AI-driven multi-layer security framework workflow diagram.

1.2 Literature Review

Fileless malware has become one of the most advanced forms of cyberattacks because it executes malicious activities directly in system memory without creating executable files on disk. Attackers typically use legitimate Windows tools such as PowerShell, Windows Management Instrumentation (WMI), and system APIs**,** allowing malicious actions to appear similar to normal administrative activities. According to recent studies, fileless attacks are increasingly used in advanced persistent threats (APTs) because they can bypass traditional signature-based antivirus solutions and remain undetected for long periods [5].

Researchers have proposed several machine learning–based techniques to detect such attacks. Khalid et al. [6] investigated the use of behavioral features extracted from memory artifacts to detect fileless malware using machine learning classifiers. Their study showed that behavioral indicators such as command execution patterns and process interactions can improve detection accuracy. However, memory-based analysis often requires forensic data collection, which may not be suitable for real-time monitoring environments.

Another approach focuses on detecting malicious PowerShell scripts**,** which are frequently used in fileless attacks. Alahmadi et al. [7] proposed a deep learning model based on stacked denoising autoencoders to identify malicious PowerShell commands. Although this approach improves script detection, it mainly analyzes script content and may fail to capture broader system behaviors such as suspicious API calls, process relationships, and WMI-based persistence mechanisms.

In the context of healthcare cybersecurity, several studies have proposed intrusion detection systems (IDS) for IoMT environments**.** Begum et al. [8] introduced a federated learning-based intrusion detection framework that allows multiple healthcare organizations to collaboratively train models without sharing sensitive data. While federated learning improves privacy preservation, many existing IoMT IDS solutions primarily analyze network traffic rather than endpoint behavioral logs, which are essential for detecting fileless malware.

Overall, existing research has made progress in malware detection using machine learning, deep learning, and network intrusion detection approaches. Nevertheless, many current solutions lack integrated behavioral analysis, explainable AI mechanisms, and privacy-preserving distributed learning tailored specifically for detecting PowerShell-based fileless malware in IoMT healthcare environments**.** This gap highlights the need for a specialized detection framework that combines endpoint telemetry analysis, machine learning models, explainable AI techniques, and federated learning to improve security in healthcare systems.

1.3 Research Gap

Although significant research has been conducted on malware detection and intrusion detection systems (IDS), several limitations remain when addressing fileless malware attacks in IoMT healthcare environments. Existing studies mainly focus on either network-level intrusion detection or script-level malware analysis**,** while the detection of endpoint behavioral anomalies related to PowerShell-based fileless malware remains insufficiently explored.

Many traditional malware detection approaches rely on signature-based techniques or static analysis methods. These approaches are effective for detecting known malware but are ineffective against fileless attacks that execute directly in memory using legitimate tools such as PowerShell and WMI**.** Since fileless malware does not leave conventional file artifacts, signature-based solutions fail to identify previously unseen or obfuscated attack techniques [10]. Additionally, several machine learning–based detection models have been proposed; however, many of them focus primarily on script content classification or memory forensics**,** which may not be suitable for real-time detection in operational healthcare environments [11].

Another limitation of current research is the lack of comprehensive behavioral monitoring at the endpoint level. Many intrusion detection frameworks developed for IoMT security concentrate mainly on network traffic analysis rather than analyzing detailed system telemetry such as process creation events, command-line activities, module loads, and WMI interactions. As a result, suspicious activities related to PowerShell abuse and in-memory execution may remain undetected within endpoint devices [12].

Furthermore, many existing machine learning–based cybersecurity systems operate as black-box models, providing limited interpretability for security analysts. In critical sectors such as healthcare, where security decisions may affect patient safety and system reliability, it is important for analysts to understand why a particular activity is classified as malicious**.** However, explainable AI techniques are rarely integrated into current fileless malware detection frameworks [13].

Another important challenge is data privacy and regulatory compliance in healthcare environments**.** Many detection models rely on centralized data collection for training machine learning models, which can raise privacy concerns when dealing with sensitive medical data and security logs from multiple hospitals. Although federated learning has been explored in some IoMT intrusion detection systems, it has rarely been applied specifically to fileless malware detection using endpoint behavioral data [14].

In addition to detection accuracy, an operational gap remains in how detection results are produced and communicated for real-world response. Many research prototypes report classification outcomes only as offline metrics and do not provide standardized, machine-readable alert outputs that can be integrated into SOC workflows or downstream security modules. In practice, healthcare environments require detection systems to generate real-time, structured alerts that include timestamps, alert categories, confidence/severity scores, evidence summaries,

and recommended actions. The absence of a consistent alert schema and export format limits the practical adoption of fileless malware detection systems and makes cross-system correlation and incident response automation more difficult.

Therefore, there is a clear need for a specialized detection framework that integrates behavioral endpoint monitoring, machine learning–based detection techniques, and an operational alerting mechanism suitable for healthcare deployments. The proposed component addresses these gaps by developing a PowerShell-based fileless malware detection system that analyzes Sysmon endpoint logs using a hybrid ensemble model and produces standardized JSON-based alerts for each detection, enabling real-time incident handling and downstream integration. By combining these capabilities, the proposed research introduces a comprehensive approach for detecting stealthy fileless malware attacks in IoMT-enabled healthcare systems, addressing key limitations identified in existing studies and security solutions.

No	Feature	Research Paper 01	Research Paper 02	Research Paper 03	Proposed Component
1	Machine Learning Integration	✓	✓	✓	✓
2	Focus on IoMT Security	✗	✗	✓	✓
3	PowerShell Fileless Malware Detection	✗	✓	✗	✓
4	Endpoint Behavioral Monitoring	✗	✗	✗	✓
5	Detection of Unknown Threats	✗	✓	✓	✓
6	Real-Time Monitoring	✗	✗	✗	✓

Table 1: Comparison of Previous Research

2. OBJECTIVES

2.1 Main Objective:

The main objective of this research is to design and develop an AI-driven behavioral detection framework capable of identifying PowerShell-based fileless malware attacks in Internet of Medical Things (IoMT) healthcare environments by analyzing endpoint telemetry data and applying advanced machine learning techniques. The framework aims to improve the detection of stealthy in-memory attacks that bypass traditional security mechanisms. By integrating behavioral monitoring and hybrid machine learning models, the system will enable accurate and near real-time detection of fileless malware threats in healthcare infrastructures, and generate standardized JSON-based alerts (with confidence scores, evidence summaries, and recommended actions) to support incident response and downstream system integration.

2.2 Specific Objectives:

1. To collect and analyze endpoint telemetry data such as Sysmon event logs, PowerShell commands, and WMI activities in order to identify behavioral patterns associated with fileless malware attacks.

2. To extract and preprocess relevant behavioral features including command-line patterns, API calls, process relationships, and encoded script characteristics for training machine learning models.

3. To apply PowerShell deobfuscation and normalization techniques to decode Base64-encoded commands and transform obfuscated scripts into a standardized representation prior to machine learning analysis.

4. To develop a hybrid machine learning model using algorithms such as XGBoost and LSTM to detect anomalous PowerShell-based activities related to fileless malware.

5. To design and implement an alert generation and JSON output module that produces standardized real-time alerts including timestamp, alert type, confidence score, evidence summary, and recommended response actions, and to generate validated sample JSON alert files.

6. To evaluate the performance of the proposed detection system using metrics such as precision, recall, F1-score, PR-AUC, and detection latency in simulated IoMT environments, including analysis under class imbalance.

3. METHODOLOGY

3.1 Research Approach

This research follows a Design Science Research (DSR) approach combined with an experimental evaluation methodology. The Design Science approach is applied to design and develop a novel AI-driven behavioral detection artifact capable of identifying PowerShell-based fileless malware in IoMT healthcare environments using endpoint telemetry. The research process includes problem identification, artifact design, implementation, and systematic evaluation.

The experimental evaluation will be conducted through controlled experiments using collected endpoint telemetry data and selected public cybersecurity datasets to measure detection performance, robustness, and operational feasibility. The results will be analyzed to validate the effectiveness and reliability of the proposed detection framework under realistic conditions.

3.2 Technical Methods and Algorithms

The proposed detection framework is based on behavioral anomaly detection using machine learning techniques. The system analyzes endpoint telemetry data collected from Windows systems to identify suspicious behaviors associated with fileless malware attacks.

The methodology consists of several technical stages:

1. Data Collection and Log Monitoring
   Endpoint telemetry data will be collected using Sysmon event logging**,** which records detailed system activities such as process creation events, command-line executions, module loading events, and Windows Management Instrumentation (WMI) interactions.

2. Data Preprocessing and Feature Extraction
   The collected logs will be parsed and processed using Python scripts. Relevant behavioral features such as command-line entropy, process relationships, API call patterns, and script execution characteristics will be extracted to create a structured dataset.

3. Deobfuscation of PowerShell Commands
   Since attackers frequently use encoded or obfuscated PowerShell scripts, deobfuscation techniques will be applied to decode Base64-encoded commands and normalize script content before analysis.

4. Machine Learning Model Development
   A hybrid machine learning model will be developed using:

   - XGBoost for classification of structured behavioral features

- Long Short-Term Memory (LSTM) neural networks for analyzing sequential patterns in system events

This ensemble approach improves the ability to detect complex multi-stage fileless attacks.

5. Alert Generation and JSON Output

To support operational use and integration with downstream modules, the framework will generate standardized alerts in JSON format for each detected suspicious event or sequence. The alert schema will include:

- timestamp, host identifier, alert type
- confidence score and severity level
- evidence summary (key indicators such as encoded command detection, suspicious tokens, and process lineage)
- recommended response actions (e.g., isolate host, review user logons, investigate outbound connections)

A set of sample JSON alert files will be generated to validate schema compliance and enable integration testing.

6. To evaluate the performance of the proposed detection system using metrics such as precision, recall, F1-score, PR-AUC, and detection latency in simulated IoMT environments, including analysis under class imbalance.

3.3 Tools and Platforms

Several tools and technologies will be used for system development and experimentation.

Tool / Platform	Purpose
Python	Data processing, machine learning model development
Sysmon (Microsoft Sysinternals)	Endpoint telemetry collection
Scikit-learn	Machine learning utilities and evaluation
XGBoost	Classification model for anomaly detection
TensorFlow / Keras	Implementation of LSTM deep learning models
SHAP / LIME	Explainable AI for model interpretation
Flower Framework	Federated learning simulation
VirtualBox / VMware	Controlled virtual environment for attack simulation

Table 2 Tools and platforms with justification

3.4 Data Collection and Ethical Considerations

The research will utilize publicly available cybersecurity datasets and simulated attack scenarios to collect data required for training and evaluation. Possible datasets include IoMT security datasets, malware behavior datasets, and sandbox-generated PowerShell attack logs.

To simulate realistic attack scenarios, benign administrative PowerShell scripts and malicious scripts will be executed in isolated virtual environments. All experiments will be conducted in a controlled laboratory environment to prevent unintended system compromise.

No real patient data or sensitive hospital information will be used during this research. All data handling procedures will follow ethical research guidelines and cybersecurity best practices to ensure responsible experimentation.

3.5 Validation Strategy and Performance Metrics

The performance of the proposed detection system will be evaluated using several standard machine learning evaluation metrics. The dataset will be divided into training and testing subsets, typically using a 70:30 split.

The following metrics will be used to evaluate system performance:

- **Accuracy** – Overall correctness of the model predictions
- **Precision** – Proportion of correctly identified malicious activities among detected threats
- **Recall (Detection Rate)** – Ability of the system to detect actual malicious activities
- **F1-Score** – Balance between precision and recall
- **False Positive Rate** – Rate of incorrectly flagged benign activities
- **Detection Latency** – Time taken to detect and generate alerts

4. HIGH-LEVEL SYSTEM ARCHITECTURE

4.1 Overview of the Proposed Solution and Its Components

The proposed system is designed to detect PowerShell-based fileless malware attacks in IoMT healthcare environments by analyzing endpoint behavioral activities in real time. The architecture combines endpoint telemetry collection, feature extraction, hybrid machine learning detection, explainable AI, federated learning, and alert generation into a unified framework.

The main components of the proposed solution are:

1. **IoMT Endpoint Environment**
   This includes healthcare endpoints and connected systems where PowerShell-based attacks may occur.

2. **Endpoint Monitoring Layer**
   Sysmon is used to collect endpoint telemetry such as process creation events, command-line execution, PowerShell activities, module loads, and WMI events.

3. **Feature Extraction and Preprocessing Layer**
   Raw logs are parsed, cleaned, and transformed into behavioral features such as entropy, process relationships, API activity, and encoded command patterns.

4. **Hybrid Detection Engine**
   The detection engine uses XGBoost for structured feature classification and LSTM for sequential behavior analysis to identify malicious activity.

5. **Explainable AI Layer**
   SHAP and LIME are integrated to explain model predictions and highlight the most influential features behind each alert.

6. **Federated Learning Layer**
   This layer enables multiple nodes or healthcare sites to train the model collaboratively without sharing raw logs, preserving privacy.

7. **Alert and Response Layer**
   When suspicious behavior is detected, the system generates anomaly alerts in JSON format for further response and integration with other framework components.

4.2 System Diagram of Components

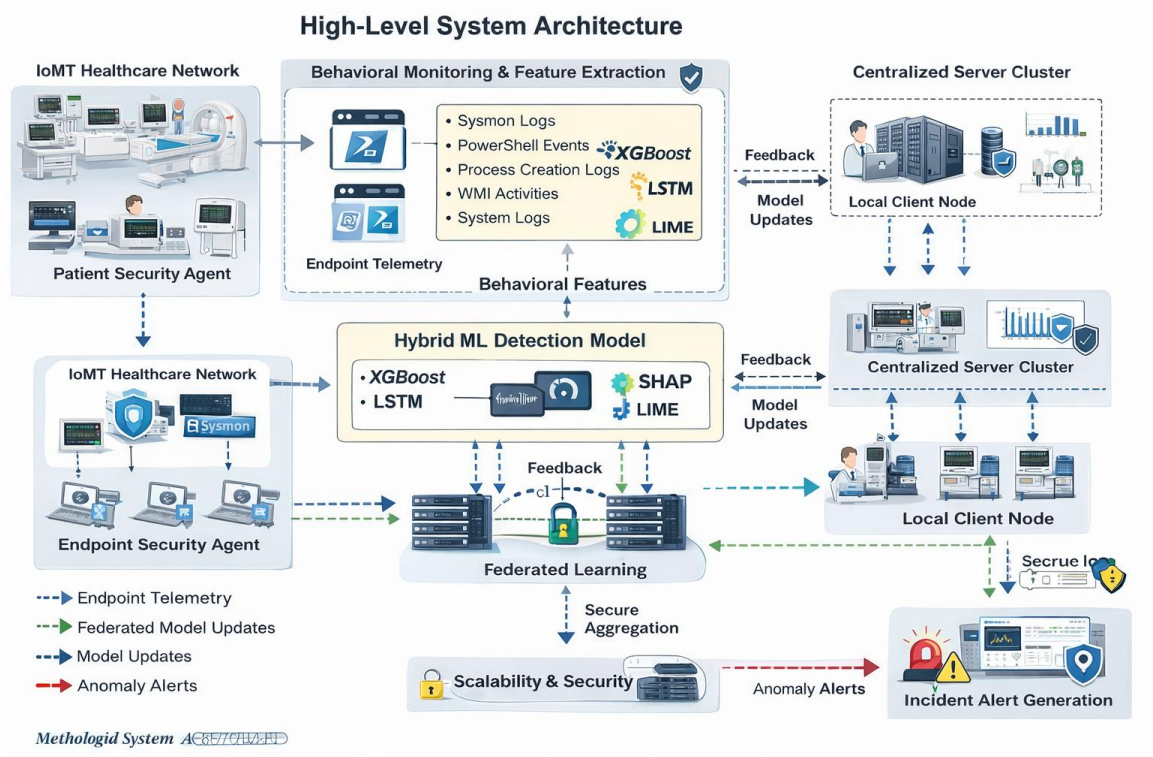


Figure 2 – High-Level System Architecture of the Proposed PowerShell-Based Fileless Malware Detection Component

4.3 Individual Component and Its Parts

The main focus of this research is the PowerShell-Based Fileless Malware Detection Component. It consists of the following internal parts:

- **Telemetry Collection Module** – captures Sysmon logs and endpoint activity data.
- **Preprocessing Module** – parses logs and performs deobfuscation of suspicious PowerShell commands.
- **Feature Engineering Module** – extracts behavioral indicators relevant to fileless malware detection.
- **Detection Module** – applies XGBoost and LSTM models to classify malicious and benign behavior.

- **Alert Generation Module** – produces actionable detection alerts for analysts or higher-level components.

4.4 Component Interactions

The IoMT endpoint first sends telemetry data to the monitoring layer, where system events are collected through Sysmon. The collected logs are then forwarded to the preprocessing and feature extraction modules. After feature generation, the processed data is passed to the hybrid detection engine, which evaluates whether the activity is benign or malicious. The explainable AI layer then interprets the prediction results, and the alert module generates a security alert if suspicious activity is detected. In parallel, federated learning supports collaborative model improvement by exchanging model updates instead of raw data.

4.5 Data Flow Explanation

1) Data Collection

• Endpoint telemetry data is collected from Windows systems using Sysmon event monitoring.
• The collected events include PowerShell execution logs, process creation events, command-line arguments, module loads, and WMI activities that may indicate suspicious behavior.

2) Data Preprocessing

• The collected logs are then parsed, cleaned, and normalized into a structured format for analysis.
• Important fields such as timestamps, process IDs, command-line parameters, user accounts, and event types are extracted and organized to prepare the dataset for machine learning analysis.

3) Feature Extraction and Behavioral Analysis

• The system extracts behavioral features from the processed logs such as command entropy, API call frequency, parent–child process relationships, and encoded PowerShell commands.
• These features help identify patterns that may indicate malicious fileless malware activity.

4) Machine Learning Detection and Explanation

• The extracted behavioral features are analyzed using the hybrid machine learning detection engine, which combines XGBoost and LSTM models.
• The Explainable AI module (SHAP or LIME) then provides explanations for why certain activities are classified as malicious.

5) Alert Generation and Response

• When suspicious behavior is detected, the system generates an anomaly alert containing the detected threat, confidence score, and explanation of the decision.
• These alerts can then be used by security analysts or integrated with other components of the framework for further threat analysis and response.

4.6 Scalability and Security Considerations

Scalability Considerations

The proposed architecture should be scalable enough to support large healthcare environments that contain many interconnected IoMT devices, hospital systems, and user endpoints. Scalability can be improved through:

- A modular system architecture that allows each component to operate independently.
- Distributed log collection and processing, enabling multiple endpoints to be monitored simultaneously.
- Efficient feature extraction and filtering to reduce unnecessary data processing.
- The use of federated learning, which allows multiple healthcare institutions to collaboratively improve detection models without centralizing large datasets.
- The ability to easily integrate additional endpoints or monitoring nodes without redesigning the entire detection system.

These improvements are important because healthcare environments often include hundreds or thousands of connected devices**,** making scalability a critical requirement.

Security Considerations

Since this component processes sensitive endpoint security logs and behavioral data, several security considerations must be implemented:

- Secure storage of collected telemetry logs to prevent unauthorized access.
- Strict access control mechanisms for system administrators and security analysts.
- Encryption of data during transmission and storage to protect sensitive information.
- Privacy-preserving federated learning, ensuring that raw security logs remain within the local environment.
- Authentication and role-based access control for monitoring dashboards and backend modules
- Audit logging mechanisms to track system access and security operations.

These security measures ensure that the proposed component does not become a vulnerability while handling sensitive healthcare cybersecurity data.

5.USER REQUIREMENTS

5.1 Stakeholder Identification

Stakeholder

Several stakeholders are involved in the implementation and use of the proposed fileless malware detection system.

Cybersecurity Analysts

Security analysts are responsible for monitoring alerts generated by the system and analyzing suspicious activities detected within the healthcare environment.

Hospital IT Administrators

IT administrators manage hospital networks and endpoints. They are responsible for deploying the detection system, maintaining system configurations, and ensuring proper integration with existing infrastructure.

Healthcare Organizations

Hospitals and healthcare institutions benefit from improved cybersecurity protection against fileless malware attacks that could disrupt medical services or compromise sensitive patient data.

Cybersecurity Researchers and Developers
Researchers and system developers are responsible for designing, improving, and maintaining the machine learning models used in the detection framework.

Patients and Medical Staff (Indirect Stakeholders)
Although they do not directly interact with the system, patients and medical staff benefit from secure healthcare infrastructure and uninterrupted medical services.

5.2 Functional Requirements

The system should provide the following functional capabilities:

FR1: The system shall collect endpoint telemetry data such as PowerShell logs, process creation events, command-line arguments, and WMI activities using Sysmon in order to monitor system behavior and detect suspicious activities.

FR2: The system shall preprocess and normalize collected log data by cleaning, organizing, and converting raw logs into a structured format suitable for analysis.

FR3: The system shall extract relevant behavioral features from the collected logs, including command entropy, process relationships, and encoded PowerShell commands that may indicate fileless malware activity.

FR4: The system shall detect suspicious PowerShell-based activities using a hybrid machine learning model that combines XGBoost and LSTM algorithms for improved anomaly detection.

FR5: The system shall generate alerts when potential fileless malware activity is detected, including details such as the detected behavior, risk level, and time of occurrence.

FR6: The system shall generate standardized JSON-based security alerts when potential fileless malware activity is detected, including at minimum: timestamp, alert type, host identifier, confidence score, severity, evidence summary (key indicators), and recommended response actions**.**

FR7: The system shall support federated learning mechanisms that allow collaborative training of machine learning models across multiple nodes without sharing raw security logs.

FR8: The system shall store detected anomaly results and generated alerts in a secure log repository for further investigation and analysis by security analysts.

5.3 Non-Functional Requirements

The system should also satisfy several non-functional requirements to ensure reliability, security, and usability.

Security Requirements

- The system must ensure secure storage of collected telemetry logs.
- All communication between system components should be encrypted.
- Access to system dashboards and analysis tools should be restricted using authentication and role-based access control.
- Sensitive security data should be protected to maintain privacy and confidentiality.

Performance Requirements

- The system should perform real-time or near real-time analysis of endpoint telemetry data.
- The detection system should minimize false positives while maintaining high detection accuracy.
- The system should efficiently process large volumes of log data from multiple endpoints.

Scalability Requirements

- The system should support monitoring of multiple IoMT devices and endpoints simultaneously.
- The architecture should allow easy integration of additional endpoints without major system modifications.

Usability Requirements

- The system should provide clear alerts and explanations for detected threats.
- Security analysts should be able to easily interpret detection results and investigate suspicious activities.
- The monitoring interface should present information in a clear and understandable format.

6. COMMERCIALIZATION PLAN

6.1 Target Market and Customer Persona

The target market of the proposed system includes organizations whose environments are infused with Internet of Medical Things (IoMT) technologies. This includes hospitals and healthcare providers whose environments are infused with medical devices, medical imaging technologies, and clinical information systems. However, environments infused with such technologies are highly vulnerable to sophisticated cyber attacks such as fileless malware attacks and lateral movement attacks.

The target market includes

- Hospitals and Healthcare Networks
- Medical Research Institutes
- Diagnostic Laboratories
- Telemedicine Service Providers
- Healthcare Cybersecurity Service Providers

The customer personas of the proposed system are

- Hospital IT Security Administrators

These are administrators responsible for monitoring hospital environments. They are responsible for the security of medical devices and patient information. This persona needs a system capable of detecting abnormal device behaviors and cyber-attacks.

- Healthcare Cybersecurity Analysts

These are security analysts working in hospital security operations centers (SOC) responsible for analyzing security alerts to identify potential cyber-attacks.

- Medical Device Security Teams

These are teams responsible for the security of medical devices such as those infused with IoMT technologies.

6.2 Value Proposition

The proposed system provides a hybrid AI-based cybersecurity solution, particularly designed for IoMT in healthcare environments, overcoming the shortcomings of existing security monitoring systems.

The main value propositions are

- Multi-layer threat detection: The system can detect threats on multiple levels, including network, endpoint, predictive threat patterns, and cross-layer attack correlation.
- Detection of stealthy fileless malware attacks: The system will be particularly designed for detection of memory-based malware attacks, which are difficult for traditional antivirus software to detect.
- Cross-layer attack correlation: The system will be able to correlate attacks from different components, thus providing a comprehensive attack chain
- Explainable AI-based threat interpretation: The system will be able to explain threats detected, helping security analysts understand the rationale for the detection.
- Healthcare-specific cybersecurity protection: Unlike existing intrusion detection systems, the proposed system will be particularly designed for IoMT in healthcare environments, medical imaging, and hospital infrastructures.

6.3 Revenue Model

The proposed system has the opportunity for revenue generation based on the Software-as-a Service (SaaS) or enterprise security solutions business model.

The possible revenue models for the proposed system are:

1. Subscription-Based Model

   The proposed system has the opportunity for generating revenue by charging a subscription fee from the healthcare organizations that utilize the proposed system for their operations.

   Example:

   The proposed system has the opportunity for generating revenue by charging a subscription fee from the healthcare organizations that utilize the proposed system for their operations. The proposed system has the opportunity for generating revenue by charging a subscription fee from the healthcare organizations that utilize the proposed system for their operations.

2. Enterprise Licensing Model

   The proposed system has the opportunity for generating revenue by allowing hospitals to purchase the proposed system for implementation in their hospital's internal cybersecurity infrastructure.

2. Security Monitoring Services

The proposed system has the opportunity for generating revenue by allowing security teams to utilize the proposed system for monitoring security threats.

3. Integration with Existing Security Platforms

The proposed system has the opportunity for generating revenue by allowing the integration of the proposed system into SIEM/SOC systems, which are utilized by cybersecurity vendors for their operations.

6.4 Pricing Strategy

The pricing strategy will be based on the tiered pricing model according to the complexity of the healthcare infrastructure.

Package	Targeted organization	Estimated Price
Basic	Small Clinic centers and laboratories	LKR.150,000.
Professional	Medium Size hospitals	LKR.450,000.
Enterprise	Large hospital networks	Customized price.

Table 3Pricing Strategy for the Proposed Cybersecurity System

Additional services like advanced threat analysis, vulnerability assessment, security consulting services may be provided as premium features.

6.5 Competitive Advantage

The proposed system has several competitive advantages over existing cybersecurity solutions.

- Healthcare-specific security design

The cybersecurity solutions available in the market are generic and can be applied to any general enterprise network. The proposed system is specifically designed for an IoMT healthcare network.

- Hybrid multi-component architecture

The system comprises four different detection components. The combination of these components can provide a comprehensive detection capability for the different layers.

- Cross-layer attack correlation capability

Unlike existing intrusion detection systems, the proposed system can correlate the detected attacks across different layers.

- Explainable AI integration

The inclusion of an XAI dashboard can help in decision-making for cybersecurity analysts.

- Proactive threat forecasting

The inclusion of a predictive threat forecasting engine can help organizations forecast potential threats.

The proposed system can offer a comprehensive cybersecurity solution compared to an existing intrusion detection system or SIEM.

6.6 Intellectual Property Considerations

It is possible that the system may incorporate intellectual properties that can be protected under different intellectual property protection schemes.

Possible intellectual properties that may be protected include:

- Software Copyright Protection

It is possible that the software platform, as well as the algorithms for correlation, AI, and dashboard systems, may be protected under software copyright protection.

- 2. Patent Protection Opportunities

It is possible that certain technical aspects of the system may be patented, such as:

o Cross-layer correlation algorithms for IoMT cybersecurity.

- AI-based attack path reconstruction mechanisms. o Explainable AI dashboards for healthcare cybersecurity.

- 3. Trade Secrets Protection

It is possible that certain aspects of the system, such as:

o Proprietary detection algorithms. o Threat correlation logic.

o Predictive threat forecasting models may be protected as trade

secrets for commercialization purposes.

It is also necessary to ensure compliance with healthcare data protection regulations such as HIPAA-like regulations and national data protection policies when deploying the system in a real-world environment

8. WORK BREAKDOWN STRUCTURE

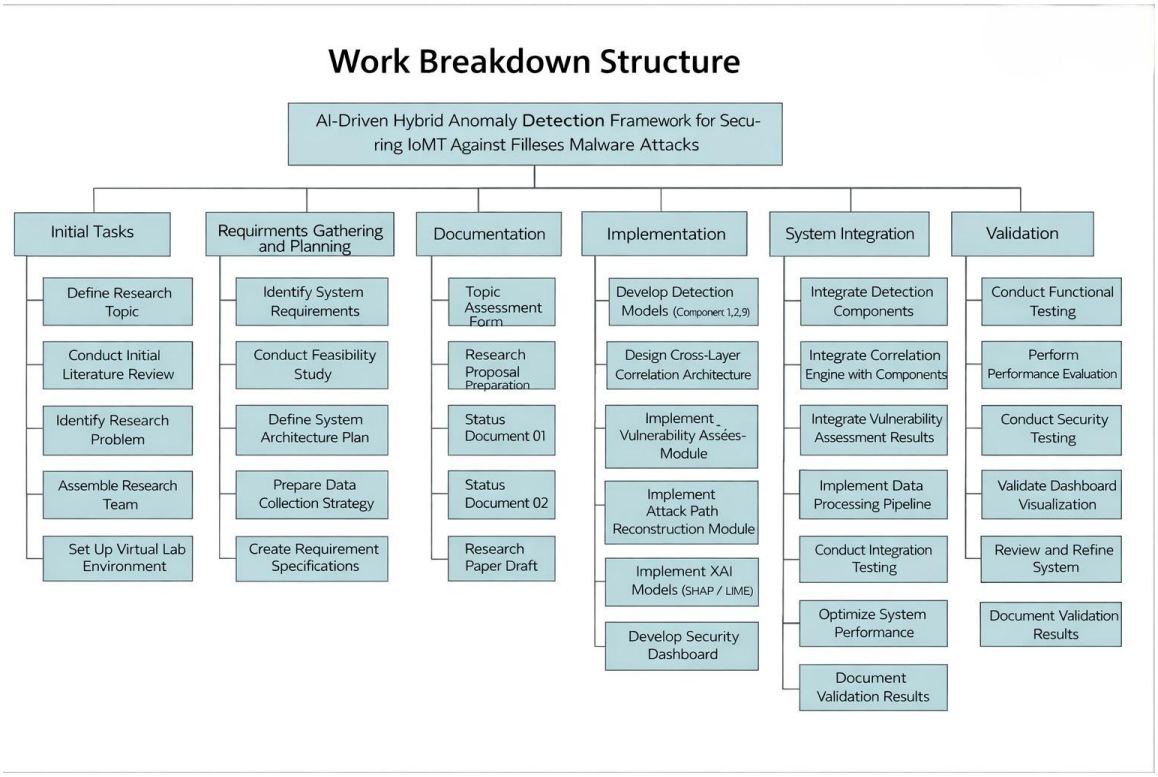


Figure 3 Work breakdown structure within the timeline

9.GANTT CHART

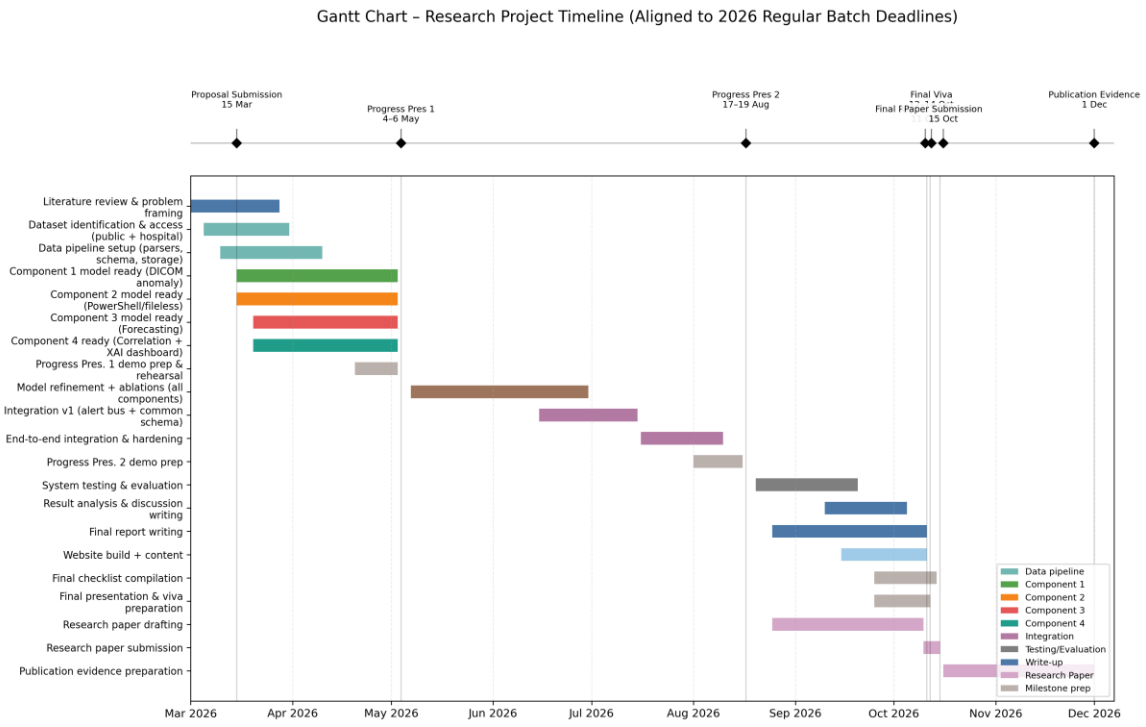


Figure 4 Overall research project gantt chart

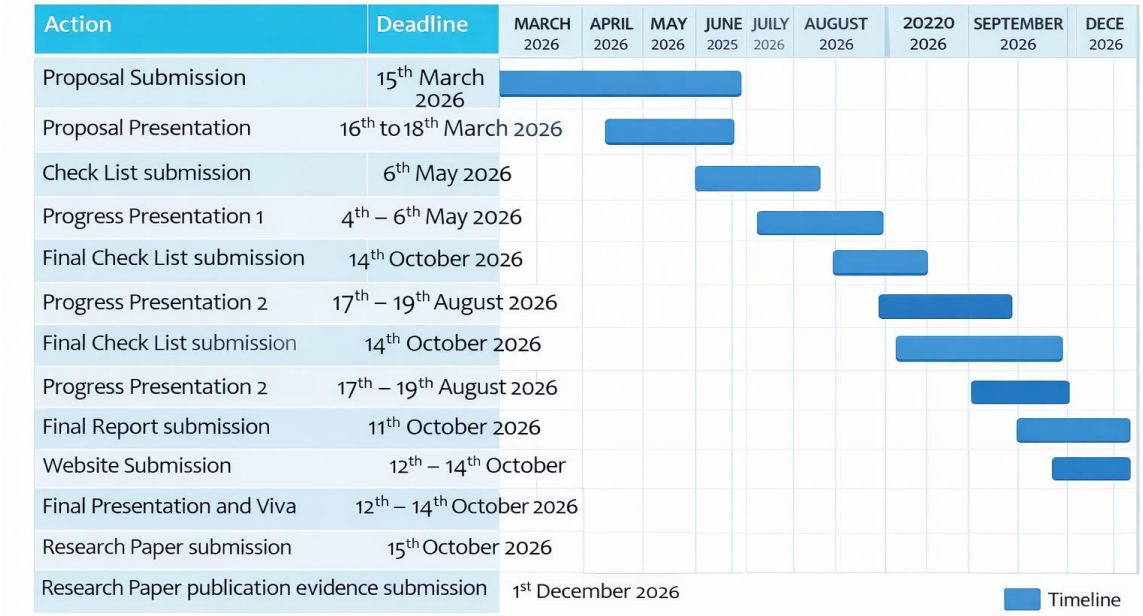


Figure 5 Component 2 gantt chart.

10.REFERENCES

[1] M. Adil, M. K. Khan, N. Kumar, M. Attique, A. Farouk, M. Guizani, and Z. Jin, "Healthcare Internet of Things: Security Threats, Challenges, and Future Research Directions," *IEEE Internet of Things Journal*, 2024.

[2] IBM Security, "Cost of a Data Breach Report 2023," IBM Corporation, 2023.

[3] R. Sihwail, K. Omar, and K. A. Zainol Ariffin, "A Survey on Malware Analysis Techniques: Static, Dynamic, Hybrid and Memory Analysis," *IEEE Access*, vol. 8, pp. 196–214, 2020.

[4] N. Idika and A. Mathur, "A Survey of Malware Detection Techniques," *ACM Computing Surveys*, vol. 48, no. 3, pp. 1–41, 2017.

[5] S. Liu et al., "A survey on the evolution of fileless attacks and detection techniques," *Computers & Security*, 2024.

[6] O. Khalid et al., "An Insight into the Machine-Learning-Based Fileless Malware Detection," *Sensors*, 2023.

[7] A. Alahmadi et al., "Malicious PowerShell Script Detection Using Deep Learning," *Computers & Security*, 2022.

[8] K. Begum et al., "Federated Learning for Intrusion Detection in IoMT Networks," *Sensors*, 2024.

[9] Microsoft, "Fileless threats – Microsoft Defender for Endpoint," Microsoft Security Documentation, 2024.

[10] S. Liu et al., "A Survey on Fileless Malware Attacks and Detection Techniques," *Computers & Security*, 2024.

[11] O. Khalid et al., "An Insight into the Machine Learning-Based Fileless Malware Detection," *Sensors*, vol. 23, no. 2, 2023.

[12] M. Adil et al., "Healthcare Internet of Things: Security Threats, Challenges, and Future Research Directions," *IEEE Internet of Things Journal*, 2024.

[13] A. Alahmadi et al., "Malicious PowerShell Script Detection Using Deep Learning," *Computers & Security*, 2022.

[14] K. Begum et al., "Federated Learning-Based Intrusion Detection for IoMT Networks," *Sensors*, 2024.